

云枢 T8 多租户开放 API

租户数据隔离修复 — 结项汇报

2026-08-16 · 项目结项汇报用

一、背景与风险

T8 多租户开放 API 灰度开放 /api/audit/logs 审计日志查询端点后，故障演练剧本场景 B 实测确认：该端点为全局 Append-only 日志，未按租户维度过滤，任意绑定租户的 API Key 可读取全部审计记录，定级为中风险（元数据级：trace_id / action / metadata，输入输出为 SHA-256 截断哈希）。

二、修复内容

		handle_request request._gateway_key_infotenant_id/role
	AuditLogger.filter_by_key	Key + warning
	log(tenant_id=...)	0
	migrate_audit_logs_tenant.py	228 system + --yes CI/
	docker_entrypoint.sh	
	analyze_audit_logs.py +	SQL SMTP .env

三、收益数据（修复记录数 / 风险量级 / 效率）

■ ■	■ ■ ■	■ ■ ■	■ ■
■■■■■■■	228 ■■ tenant_id	■■■■■■■ system	228 ■■■■■■■■+■■■■■■■
■■■■■■■■■	233 ■■100% ■■■■	0 ■	■■■■■■■■■■■■■■■■■■■■
■■■■■	■■■ Key ■■■■	■■■■■■■97.85% ■■■■■■■■■■	■■■■ → ■
■■■■■■■	—	■■■■■	0 ■■■■■■■■
■■■■■	—	RBAC 30 + ■■ 13 ■■	■■■■■ 101 passed / 0 failed
■■■■■	■■■■■	■■■■■■■■■ + ■■■■	401/403/429 ■■■■■■■■

风险消除量级：修复前跨租户可读率为 100% (233/233)，修复后绑定租户 Key 仅可读本租户记录，跨租户可见记录 233 → 0；审计字段 (trace id/action/metadata) 不再跨租户泄露。

四、故障演练结果 (2026-08-16 重跑)

场景 A — 网关宕机

单进程架构：网关与内部 API 同进程，宕机即全挂。数据 RPO≈0（租户/Key/审计日志磁盘持久化），限流/配额内存态重启重置（符合预期）。恢复判定 4

场景 B — 租户数据隔离 (含 401/403/429 验证)

日志定位四步法：① 响应体 error 字段 → ② /api/open/stats 网关统计 → ③ app_server 结构化日志 access 条目 → ④ /api/audit/logs 审计记录（成功请求）。跨租户隔离正向验证：租户 B owner Key 查询 count=1（仅本租户），跨租户记录 0。

SQL 分析实测 (233 条) : 租户分布 system 228 (97.85%)、演练租户记录 5; 状态 100% success (异常占比 0%, 未触发告警阈值); 按日分布 07-05 → 08-16。

■	■■	■■
■■ system ■■■■	■■■	■■■■ Key ■■■■■■■■■■■■■■■■■■
■■■■■■■■■■■■■■ tenant_id	■■■■	■■■■■■■■■■■■■■■■■■
Docker ■■■■■■	■■■	daemon ■■■ docker compose up■■■■ torch CPU ■■■
■■■■■■■	■■■■	■ .env ■■ SMTP_HOST/TO ■■■

结语：租户隔离修复完成闭环 —— 风险暴露（演练发现）→ 读侧隔离 + 写侧字段 + 历史迁移 + 自动注入 + 容器集成 + 告警可观测，收益数据全量实测。